

Phase 1 — Implementation Report

Approved baseline work: security nits, cancellation and Driver access rules, expenses, notifications, currency display, UI polish, and tests. SaaS conversion has not started.

Document type	Phase 1 implementation and QA report
Date	17 September 2026
Automated tests	26 passed, 0 failed
Typecheck	<code>npx tsc --noEmit</code> — clean
Schema changes	None
Packages added	None

Contents

- A. Changes made
 - B. Files modified
 - C. Files created
 - D. Packages installed
 - E. Database / schema changes
 - F. Bugs fixed
 - G. Security fixes
 - H. Permission changes
 - I. UI/UX changes
 - J. Tests performed
 - K. Tests passed
 - L. Tests failed
 - M. Remaining issues
 - N. Changes intentionally not made
 - O. Recommendations for Phase 2 SaaS conversion
 - P. Driver-to-User linking limitation and recommended future solution
-

A. Changes made

Phase 1 implemented the approved safe baseline work on the current single-tenant RedKnot Rent-a-Car system. No SaaS, multi-tenancy, companyId, subscriptions, Google OAuth, email verification, or global blacklist work was started. Business formulas were not changed.

Rental cancellation

cancelRental now requires rentals.cancel instead of rentals.edit. Employee/Staff can no longer cancel a hire. ADMIN and SUPER_ADMIN still can. The Cancel button was already hidden without rentals.cancel; the server action is now aligned with that UI.

Driver receipt and record access

The DRIVER role was kept. A User is still not linked to a Driver master record. Immediate unauthorized access was closed without that architecture change: Drivers cannot open /rentals/[id] (including receipt and refund pages) via middleware or the page guard; hire receipt HTML/PDF requires rentals.receipt (Employee and administrators only); owner and broker settlement PDFs require settlements.view only (Drivers never had that permission, but previously rentals.view was enough).

Expenses

Employee/Staff: view and create only. ADMIN and SUPER_ADMIN: view, create, edit, and delete. Edit and delete UI and server actions were added. Staff cannot reach /expenses/[id]/edit or call deleteExpense.

Health endpoint

/api/health now returns only { status: "ok" }. It no longer reports AUTH_SECRET presence, NEXTAUTH_URL, Vercel, database connectivity, or hints.

Broadcast notifications

Marking a company-wide notification (userId null) as read no longer flips isRead on the shared row. A per-user read receipt is stored as a Notification row with entityType BROADCAST_READ. Other users still see the broadcast as unread. No Prisma schema change was required.

Currency display

formatCurrency now uses Settings currency_symbol. DashboardShell loads the setting and provides it to client forms. Numeric calculations were not changed.

UI/UX

Sidebar items, order, Rentals MAIN badge, desktop sidebar, and mobile tab bar were preserved. Visual hierarchy, spacing, tables, empty states, login, and reduced motion were improved.

B. Files modified

- src/lib/permissions/index.ts — new permissions; Employee expenses; Driver hire-record route block.
 - src/lib/auth/session.ts — requireNonDriver helpers.
 - src/app/rentals/actions.ts — cancel uses rentals.cancel.
 - src/app/rentals/[id]/page.tsx — Drivers cannot open hire details.
 - src/app/rentals/[id]/receipt/page.tsx — rentals.receipt required.
 - src/app/api/rentals/[id]/receipt/route.ts — rentals.receipt required.
 - src/app/api/settlements/owner/[id]/receipt/route.ts and broker equivalent — settlements.view only.
-

- src/app/api/health/route.ts — public liveness only.
- src/lib/services/notification.ts — per-user broadcast read receipts.
- src/app/expenses/actions.ts — updateExpense and deleteExpense.
- src/app/expenses/[id]/page.tsx — Edit/Delete for administrators.
- src/components/expenses/expense-form.tsx — create and edit; settings currency label.
- src/lib/utils/index.ts — settings-driven formatCurrency.
- src/lib/services/settings.ts — applies currency_symbol as display default.
- src/components/layout/* — currency provider, sidebar grouping, header, spacing.
- src/components/ui/card.tsx and table.tsx — quieter commercial styling.
- src/app/login/login-form.tsx — removed seeded password from the login screen.
- package.json — test script includes new Phase 1 tests.
- Payment, settlement, vehicle, damage, and driver amount labels — currency_symbol.

C. Files created

- src/lib/auth/driver-access.ts
- src/lib/services/notification-read.ts
- src/components/currency-provider.tsx
- src/components/expenses/delete-expense-button.tsx
- src/app/expenses/[id]/edit/page.tsx
- src/lib/permissions/permissions.test.ts
- src/lib/services/notification-read.test.ts
- src/lib/services/phase1-access.test.ts
- scripts/generate-phase1-implementation-pdf.ts

D. Packages installed

None. No new npm packages were added.

E. Database / schema changes

None. prisma/schema.prisma was not changed. No migrations were run. Broadcast read state reuses the existing notifications table with entityType = BROADCAST_READ rather than a new table.

F. Bugs fixed

- Employee could cancel a rental because cancelRental used rentals.edit.
- One user marking a broadcast notification read marked it read for everyone.
- Hardcoded Rs. ignored Settings currency_symbol on amounts and several form labels.
- Expense administrators had no edit/delete path even though the product needed owner-level management.

G. Security fixes

- /api/health no longer leaks environment or database status.
-

- Login page no longer displays the seeded admin password.
- Hire receipt HTML and PDF require rentals.receipt. Drivers cannot open them by changing the rental id.
- Middleware blocks DRIVER from every /rentals/* path except the list /rentals.
- Hire detail page also refuses DRIVER even if middleware is bypassed in a later change.
- Settlement PDFs no longer accept rentals.view as a substitute for settlements.view.

H. Permission changes

rentals.cancel	Still SUPER_ADMIN and ADMIN only. Now actually enforced on cancelRental.
rentals.receipt	New. SUPER_ADMIN, ADMIN, EMPLOYEE. Not DRIVER.
expenses.view / create	Added to EMPLOYEE so Staff can record and see expenses.
expenses.edit / delete	New. SUPER_ADMIN and ADMIN only. Not EMPLOYEE.
DRIVER	Still dashboard, rentals.view (list only), notifications. No receipts, no hire records.

I. UI/UX changes

- All 17 sidebar items remain in the same order: Dashboard, Customers, Vehicles, Owners, Drivers, Brokers, Rentals, Payments, Damages, Settlements, Maintenance, Expenses, Reports, Notifications, Audit Log, Settings, Users.
- Rentals MAIN badge kept.
- Desktop left sidebar and mobile bottom tab bar kept.
- Sidebar grouped visually into Operations, Finance, and System without relocating items.
- Reduced hover motion and dashboard pulse animations for all-day use.
- Tables: header background, tracking, and more comfortable cell padding.
- Cards: lighter shadow, slightly smaller titles.
- Empty states: dashed panel, clearer copy hierarchy.
- Login: professional sign-in copy; credentials hint removed.
- Expense detail: Edit and Delete only when the user has permission.

J. Tests performed

Automated: npm test (tsx). Coverage includes existing pricing/commission tests plus new permission, driver access, notification overlay, deposit remaining, cancel-transition, and currency display tests. Typecheck: npx tsc --noEmit (clean).

Manual browser QA of every module against production was not run in this pass. After you deploy a Randills96-authored commit, hire cancel, Driver URL probes, expense edit/delete, notification read, and Settings currency_symbol should be smoke-tested live.

K. Tests passed

26 automated tests passed, 0 failed. Suites: role permissions, rental days, pricing, balance, broker commission, owner settlement, vehiclePaysAnOwner, deriveOwnerRatesFromCustomerRates, broadcast notification read state, rental cancel transitions, security deposit remaining, currency display.

L. Tests failed

None in this Phase 1 automated run.

M. Remaining issues

- DRIVER can still open /rentals (the list) and the dashboard, which still show company-wide hire data. Record pages and receipts are blocked. Proper scoping needs User!"Driver linking in Phase 2.
- JWT role/status can remain stale until idle timeout or 8-hour maxAge.
- Uploads remain on the Vercel local disk and will not survive deploys.
- Unique codes still use count()+1 and can race under concurrent creates.
- Anyone with customers.view can fetch any customer document id (single-tenant IDOR pattern).
- Anyone with users.create can still assign SUPER_ADMIN (today only SUPER_ADMIN has users.create).
- No login rate limit or logout.
- Some instructional example copy still mentions Rs. in help text; live amounts use Settings.

N. Changes intentionally not made

- No Company, companyId, tenantId, or Prisma schema change.
- No Platform Super Admin UI, Company Owner role rename, subscriptions, grace period, or annual pricing.
- No Google OAuth, email verification, or password reset.
- No global NIC blacklist.
- No S3/R2 migration.
- No dynamic per-company branding (RedKnot branding kept).
- No change to rental pricing, extra KM, deposit math, payment totals, settlements, commissions, or profit formulas.
- No sidebar item removed, renamed, merged, or relocated.
- No replacement of Next.js, Prisma, NextAuth, or UI libraries.
- No packages installed.

O. Recommendations for Phase 2 SaaS conversion

- Git-checkpoint this Phase 1 baseline after production smoke QA.
 - Add Company and companyId on tenant rows; Prisma query filter; IDOR tests Company A vs B.
 - Split today's SUPER_ADMIN into platform SUPER ADMIN (separate UI) and Company Owner.
 - Map Employee to Staff with this Phase 1 expense/cancel matrix as the starting point.
 - Replace global SystemSetting with per-company branding and currency.
 - Move files to object storage with tenant prefixes.
 - Key dashboard cache by companyId.
 - Global blacklist by unique NIC, warn on hire, do not hard-block.
 - Configurable subscription amounts (do not hardcode 85,000 / 20,000).
-

- Link DRIVER users to Driver records before exposing assigned-hire-only access.

P. Driver-to-User linking limitation and recommended future solution

Today a login User with role DRIVER is not related to the Driver master table. There is no driverId (or userId on Driver) that would tell the app which hires that person is assigned to. Therefore Phase 1 cannot safely show “only my jobs”. The safe choice was to keep the role, keep the Rentals list permission, and block record-level hire pages, receipts, and settlement PDFs.

Recommended Phase 2/RBAC solution: add a required link from User to Driver for DRIVER-role accounts (Driver.userId unique, or User.driverId). Authorize hire access as: authenticated user + companyId + (role/permission) + (rental.driverId === session.driverId, or staff/owner unrestricted within the company). Do not rely on hiding buttons. Platform Super Admin remains a separate UI and must not use this company sidebar.

Phase 1 implementation is complete for the approved scope. Do not start Phase 2 SaaS conversion until this baseline is reviewed and approved.

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

Prepared 17 Sep 2026 · Phase 1 complete · SaaS conversion not started

